

Πανεπιστήμιο Δυτικής Αττικής
Σχολή Μηχανικών
Τμήμα Μηχανικών Πληροφορικής και Υπολογιστών

Ασφάλεια στην τεχνολογία της πληροφορίας

3η Εργασία

ΝΙΚΟΛΑΟΣ ΘΩΜΑΣ
ΑΜ: 21390068

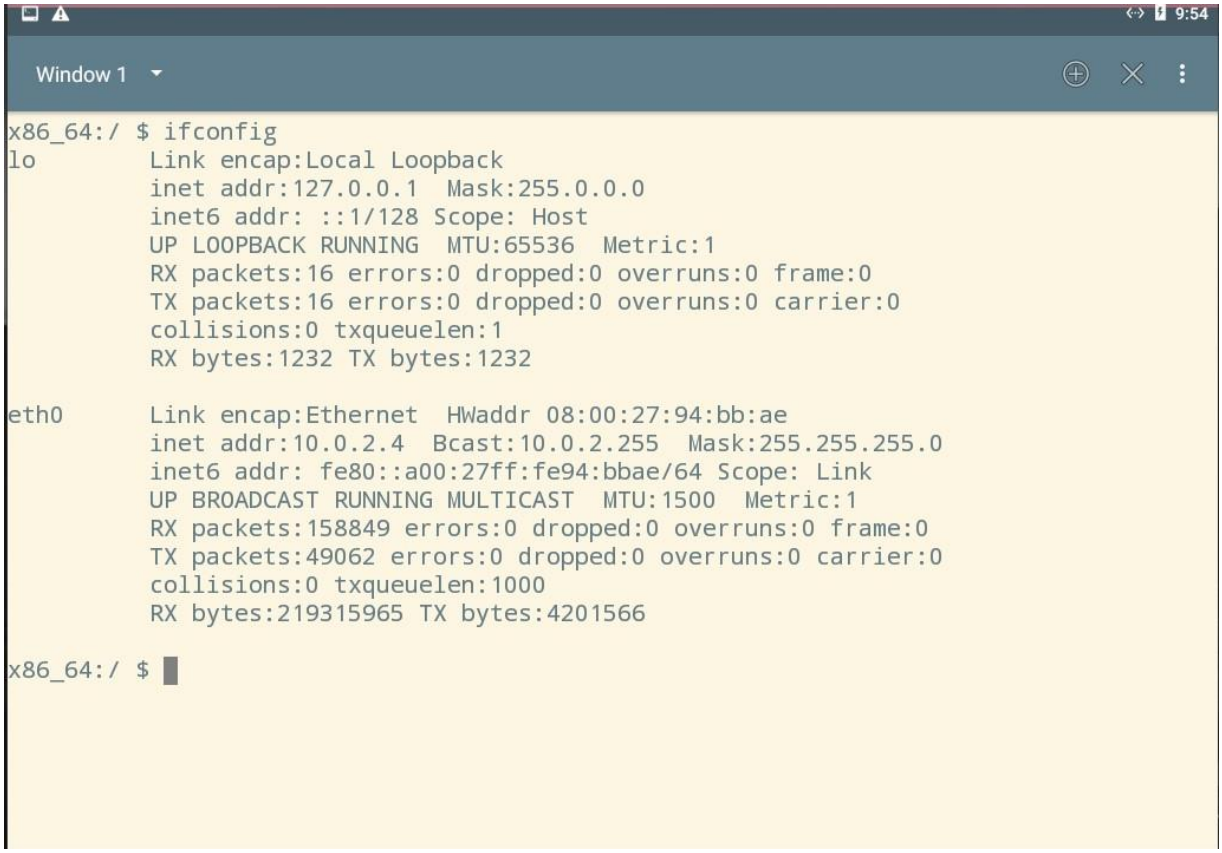
ΑΘΗΝΑ

Περιεχόμενα

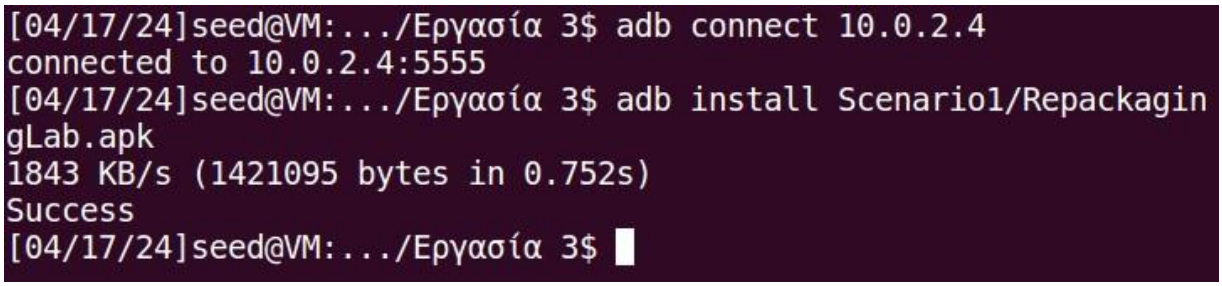
Δραστηριότητα 1: Λήψη και εγκατάσταση εφαρμογής-στόχου 3
Δραστηριότητα 2: Αποσυναρμολόγηση της εφαρμογής 6
Δραστηριότητα 3: Ενσωμάτωση κακόβουλου κώδικα 7
Δραστηριότητα 4: Επανασυναρμολόγηση της εφαρμογής 8
Δραστηριότητα 5: Εκτέλεση της επίθεσης 9
Δραστηριότητα 6: Παρακολούθηση της τοποθεσίας του θύματος 12
Παραπομπές: 17

Δραστηριότητα 1: Λήψη και εγκατάσταση εφαρμογής-στόχου

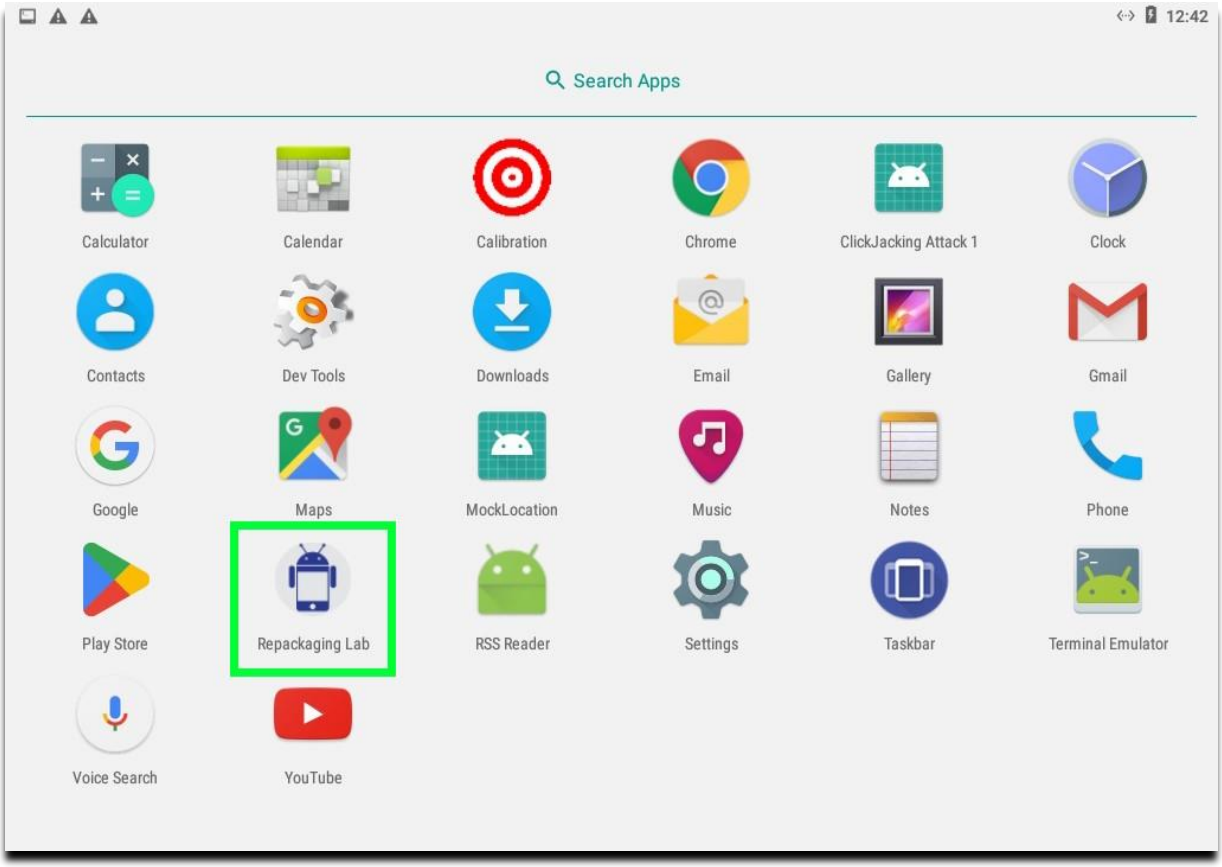
Για την εγκατάσταση της εφαρμογής υπάρχουν δύο τρόποι (adb και sideloading). Στην αρχή δοκιμάζουμε το adb που ουσιαστικά ο επιτιθέμενος εγκαθιστά την εφαρμογή στην συσκευή στόχο, αρκεί η συσκευή αυτή να έχει ενεργοποιημένο το USB Debugging από τις ρυθμίσεις.



Εικόνα 1: Διεύθυνση IP του SEEDAndroid VM με εντολή ifconfig.



Εικόνα 2: Σύνδεση και εγκατάσταση στο SEEDAndroid VM χρησιμοποιώντας το adb.



Εικόνα 3: Η εφαρμογή εγκαταστάθηκε επιτυχώς.

Το sideloading ουσιαστικά, είναι η ανάρτηση της εφαρμογής σε κάποιο δικτυακό server (είτε αυτό είναι κάποιο app store, είτε με κάποιο fishing email) με σκοπό να την κατεβάσει ο χρήστης της συσκευής στόχου.

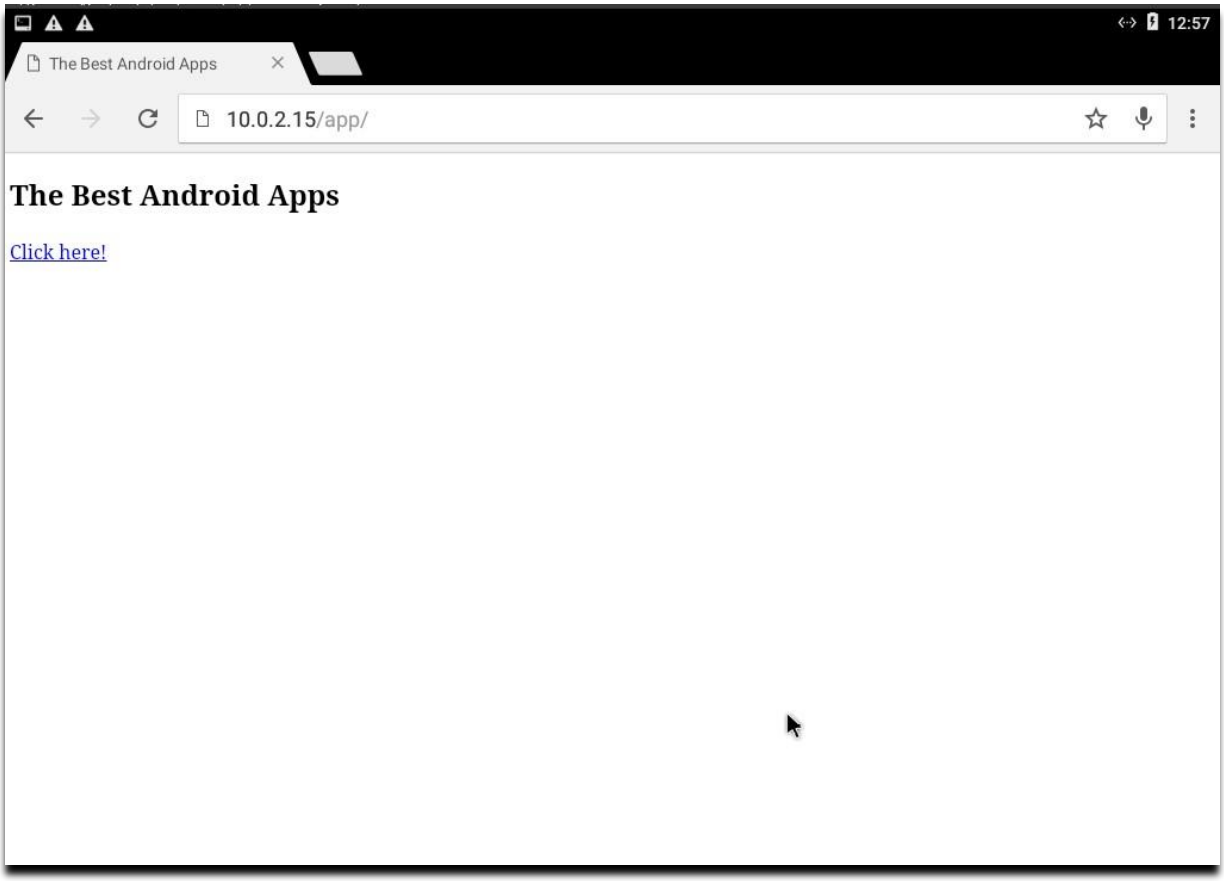
index.html

```
1   <!DOCTYPE html>
2   <html>
3
4   <head>
5       <title>The Best Android Apps</title>
6   </head>
7
8   <body>
9       <h2>
10          The Best Android Apps
11      </h2>
12
13      <a href="RepackagingLab.apk" download>
14          Click here!
15      </a>
16  </body>
17
18  </html>
```

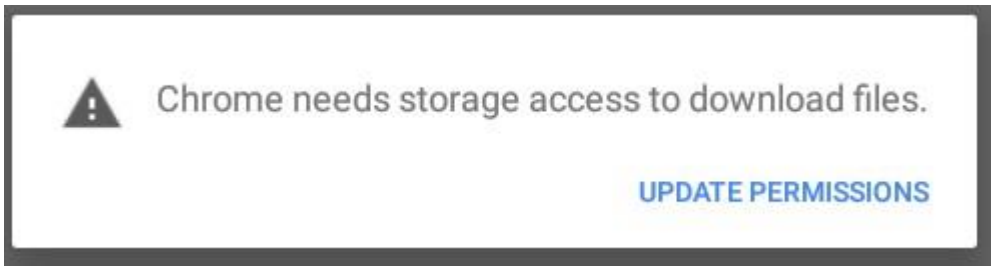
Εικόνα 4: Κώδικας HTML για τη λήψη της εφαρμογής.

```
[04/17/24]seed@VM:.../Εργασία 3$ mv RepackagingLab.apk /var/www/h
tml/app
mv: cannot create regular file '/var/www/html/app/RepackagingLab.
apk': Permission denied
[04/17/24]seed@VM:.../Εργασία 3$ sudo mv RepackagingLab.apk /var/
www/html/app
[04/17/24]seed@VM:.../Εργασία 3$ sudo service apache2 restart
[04/17/24]seed@VM:.../Εργασία 3$
```

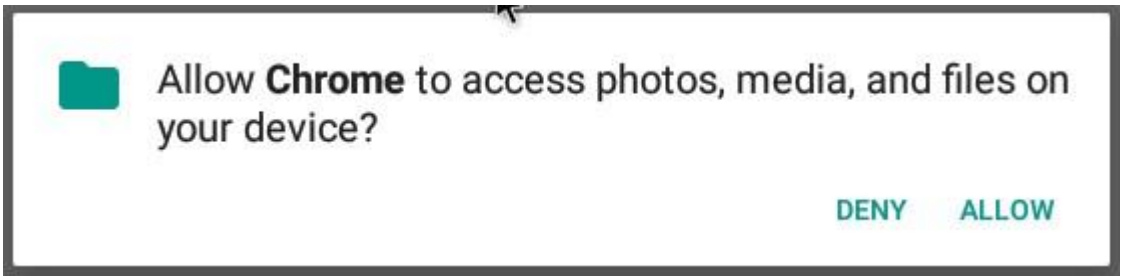
Εικόνα 5: Δημοσίευση της σελίδας στον Apache Server.



Εικόνα 6: Σελίδα για εγκατάσταση της εφαρμογης (sideloading).



Εικόνα 7: Το Chrome ζητά δικαιώματα για εγκατάσταση εφαρμογών (άγνωστες πηγές).



Εικόνα 8: Το Chrome ζητά δικαιώματα.

Δραστηριότητα 2: Αποσυναρμολόγηση της εφαρμογής

Για να ενσωματώσουμε τον κακόβουλο κώδικα θα πρέπει πρώτα να αποσυναρμολογήσουμε την εφαρμογή (ανοίξουμε). Στην συγκεκριμένη περίπτωση αυτό γίνεται με την εντολή $ apktool d RepackagingLab.apk.

```
[04/17/24]seed@VM:.../Εργασία 3$ apktool d Scenario1/RepackagingL
ab.apk
I: Using Apktool 2.2.2 on RepackagingLab.apk
I: Loading resource table...
I: Decoding AndroidManifest.xml with resources...
I: Loading resource table from file: /home/seed/.local/share/apkt
ool/framework/1.apk
I: Regular manifest package...
I: Decoding file-resources...
I: Decoding values */* XMLs...
I: Baksmaling classes.dex...
I: Copying assets and libs...
I: Copying unknown files...
I: Copying original files...
[04/17/24]seed@VM:.../Εργασία 3$
```

Εικόνα 9: Αποσυναρμολόγηση της εφαρμογής με το apktool.

Δραστηριότητα 3: Ενσωμάτωση κακόβουλου κώδικα

Αφού αποσυναρμολογήσαμε την εφαρμογή, τώρα θα ενσωματώσουμε τον κακόβουλο κώδικα smali στα αρχεία του προγράμματος.

```
[04/17/24]seed@VM:.../Scenario1$ clear

[04/17/24]seed@VM:.../Scenario1$ mv MaliciousCode.smali ../Repack
agingLab/smali/com
[04/17/24]seed@VM:.../Scenario1$
```

Εικόνα 10: Μετακίνηση του αρχείου με τον κακόβουλο κώδικα στον φάκελο smali/com.

Στην συνέχεια, θα επεξεργαστούμε το AndroidManifest.xml ώστε να προσθέσουμε τις δύο απαιτούμενες άδειες για την λειτουργία του κακόβουλου κώδικα. Τέλος, θα πρέπει να καταχωρήσουμε τον BroadcaseReceiver ώστε να λαμβάνει το συμβάν εκπομπής TIME SET.

index.html | AndroidManifest.xml

```
1  <?xml version="1.0" encoding="utf-8" standalone="no"?>
2  <manifest xmlns:android="http://schemas.android.com/apk/res/android"
   package="com.mobiseed.repackaging" platformBuildVersionCode="23"
   platformBuildVersionName="6.0-2166767">
3      <uses-permission android:name="android.permission.READ_CONTACTS" />
4      <uses-permission android:name="android.permission.WRITE_CONTACTS" />
5      <application android:allowBackup="true" android:debuggable="true"
       android:icon="@drawable/mobiseedcrop" android:label="@string/app_name"
        android:supportsRtl="true" android:theme="@style/AppTheme">
6          <activity android:label="@string/app_name" android:name="
           com.mobiseed.repackaging.HelloMobiSEED" android:theme="@style/
           AppTheme.NoActionBar">
7              <intent-filter>
8                  <action android:name="android.intent.action.MAIN"/>
9                  <category android:name="android.intent.category.LAUNCHER"
                   />
10             </intent-filter>
11         </activity>
12         <receiver android:name="com.MaliciousCode" >
13             <intent-filter>
14                 <action android:name="android.intent.action.TIME_SET" />
15             </intent-filter>
16         </receiver>
17     </application>
18 </manifest>
19
```

Εικόνα 11: Επεξεργασία του AndroidManifest.xml.

Δραστηριότητα 4: Επανασυναρμολόγηση της εφαρμογής

Εφόσον τελειώσαμε τα παραπάνω βήματα, θα πρέπει τώρα να επανασυναρμολογήσουμε την εφαρμογή. Στο συγκεκριμένο παράδειγμα με την εντολή $ apktool b RepackagingLab.apk.

```
[04/17/24]seed@VM:.../Εργασία 3$ apktool b RepackagingLab
I: Using Apktool 2.2.2
I: Checking whether sources has changed...
I: Checking whether resources has changed...
I: Building resources...
I: Building apk file...
I: Copying unknown files/dir...
[04/17/24]seed@VM:.../Εργασία 3$
```

Εικόνα 12: Επανασυναρμολόγηση της εφαρμογής με το apktool.

Στη συνέχεια θα δημιουργήσουμε το ζεύγος κλειδιών (δημόσιο και ιδιωτικό) με το εργαλείο keytool.

```
[04/25/24]seed@VM:.../3rd try 6$ keytool -alias thomas -genkey -v
 -keystore mykey.keystore
Enter keystore password:
Re-enter new password:
What is your first and last name?
  [Unknown]:  Nikolaos Thomas
What is the name of your organizational unit?
  [Unknown]:  UNIWA
What is the name of your organization?
  [Unknown]:  UNIWA
What is the name of your City or Locality?
  [Unknown]:  UNIWA
What is the name of your State or Province?
  [Unknown]:  UNIWA
What is the two-letter country code for this unit?
  [Unknown]:  UNIWA
Is CN=Nikolaos Thomas, OU=UNIWA, O=UNIWA, L=UNIWA, ST=UNIWA, C=UN
IWA correct?
  [no]:  YES

Generating 2,048 bit DSA key pair and self-signed certificate (SH
A256withDSA) with a validity of 90 days
        for: CN=Nikolaos Thomas, OU=UNIWA, O=UNIWA, L=UNIWA, ST=U
NIWA, C=UNIWA
```

Εικόνα 13: Δημιουργία ζεύγους κλειδιών.

Αφού δημιουργήσουμε το ζεύγος κλειδιών με το πρόγραμμα jarsigner θα υπογράψουμε το νέο αρχείο APK.

```
[04/25/24]seed@VM:.../3rd try 6$ jarsigner -keystore mykey.keysto
re RepackagingLab.apk thomas
Enter Passphrase for keystore:
jar signed.

Warning:
The signer certificate will expire within six months.
No -tsa or -tsacert is provided and this jar is not timestamped.
Without a timestamp, users may not be able to validate this jar a
fter the signer certificate's expiration date (2024-07-24) or aft
er any future revocation date.
```

Εικόνα 14: Ψηφιακή υπογραφή του νέου αρχείου APK.

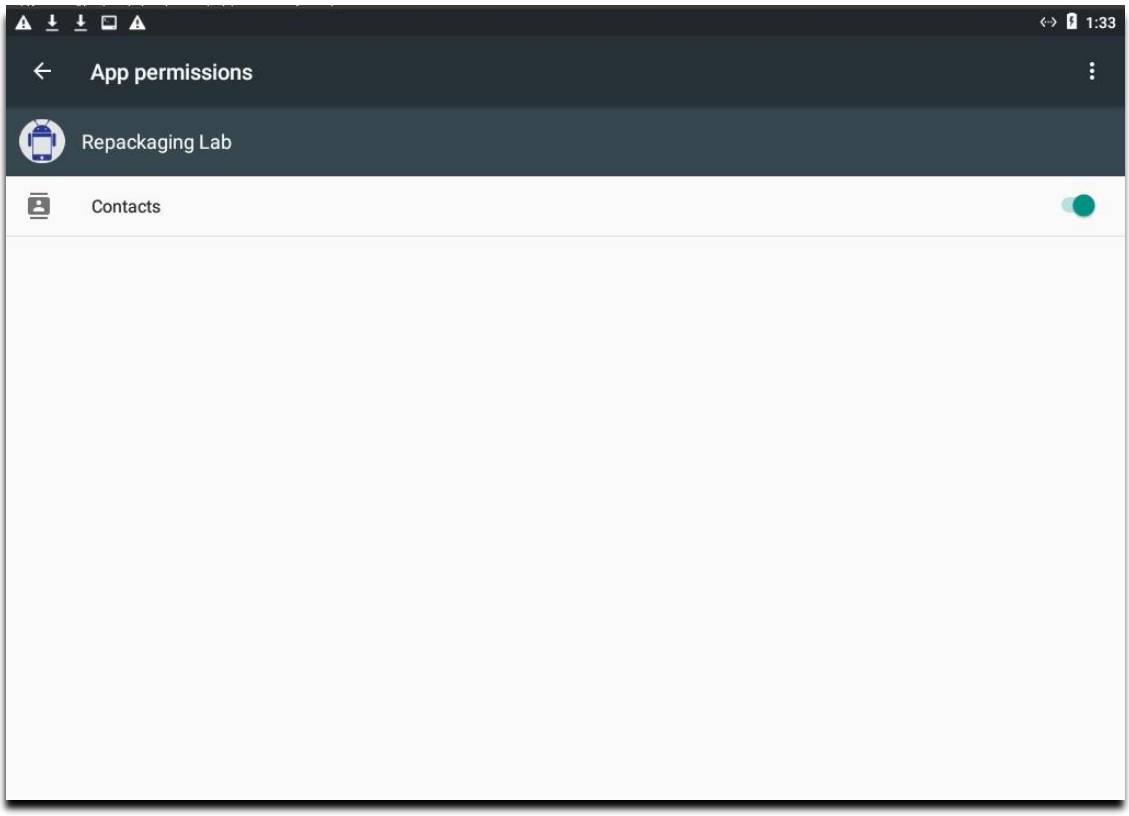
Δραστηριότητα 5: Εκτέλεση της επίθεσης

Για την εκτέλεση της επίθεσης, θα πρέπει πρώτα να εγκαταστήσουμε την εφαρμογή στη συσκευή android, είτε με sideloading είτε με adb. Στην συγκεκριμένη περίπτωση χρησιμοποιούμε το adb. Συνδεόμαστε στην συσκευή και εγκαθιστάμε την εφαρμογή.

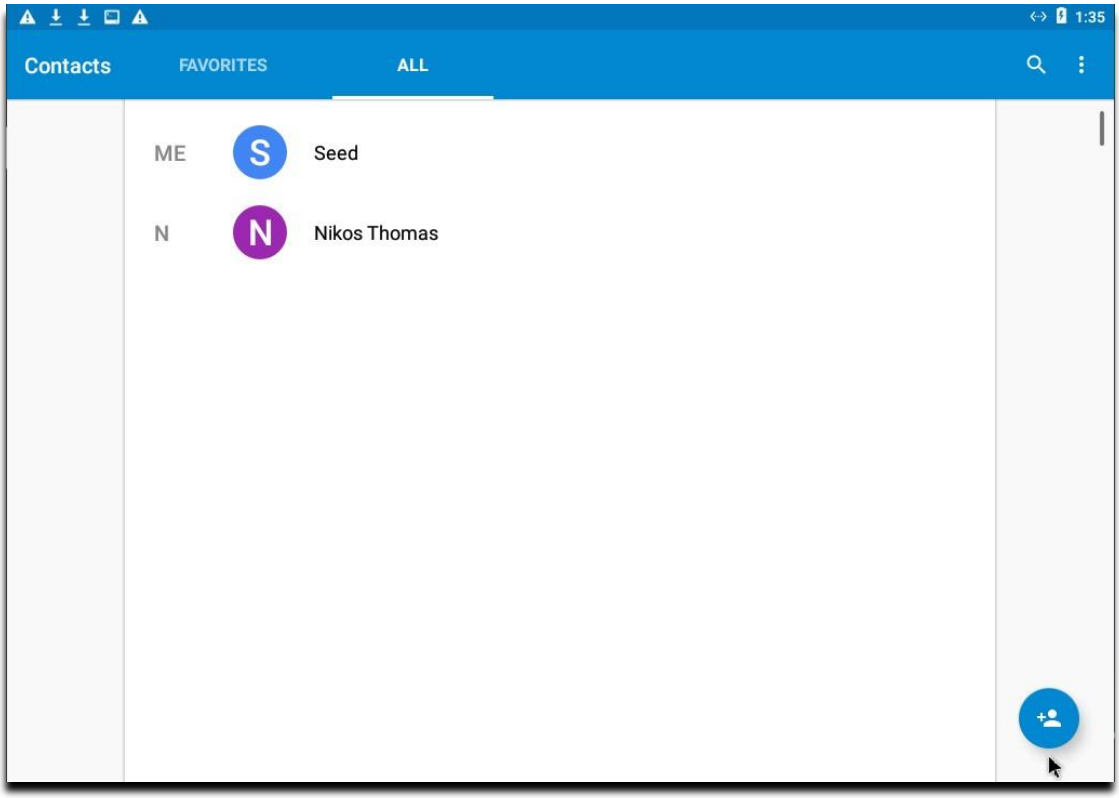
```
[04/17/24]seed@VM:.../dist$ adb connect 10.0.2.4
already connected to 10.0.2.4:5555
[04/17/24]seed@VM:.../dist$ adb install RepackagingLab.apk
1677 KB/s (1427439 bytes in 0.830s)
Success
[04/17/24]seed@VM:.../dist$
```

Εικόνα 15: Εγκατάσταση του apk στο SEEDAndroid VM χρησιμοποιώντας το adb.

Μετά την εγκατάσταση, θα πρέπει χειροκίνητα να δώσουμε τα απαιτούμενα δικαιώματα (για να λειτουργήσει ο κακόβουλος κώδικας) στην εφαρμογή από τις ρυθμίσεις (Contacts).

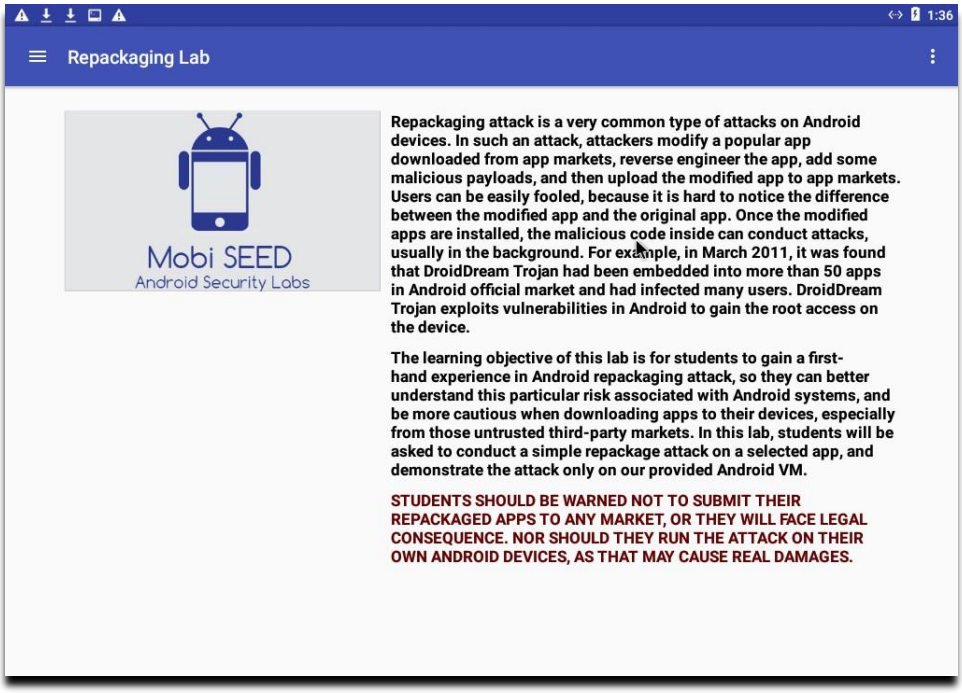


Εικόνα 16: Παραχώρηση των απαιτούμενων δικαιωμάτων.



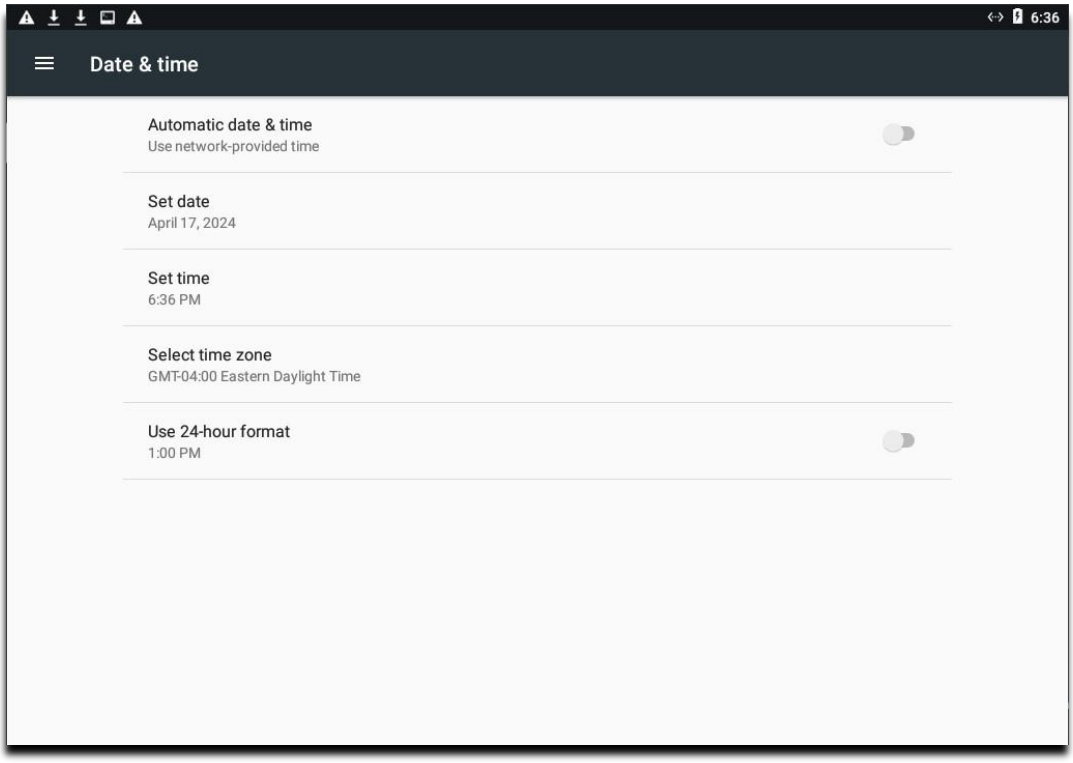
Εικόνα 17: Οι επαφές στο Android VM.

Για να εκτελεστεί ο κακόβουλος κώδικας θα πρέπει να έχουμε ανοίξει τουλάχιστον μία φορά την κακόβουλη εφαρμογή.



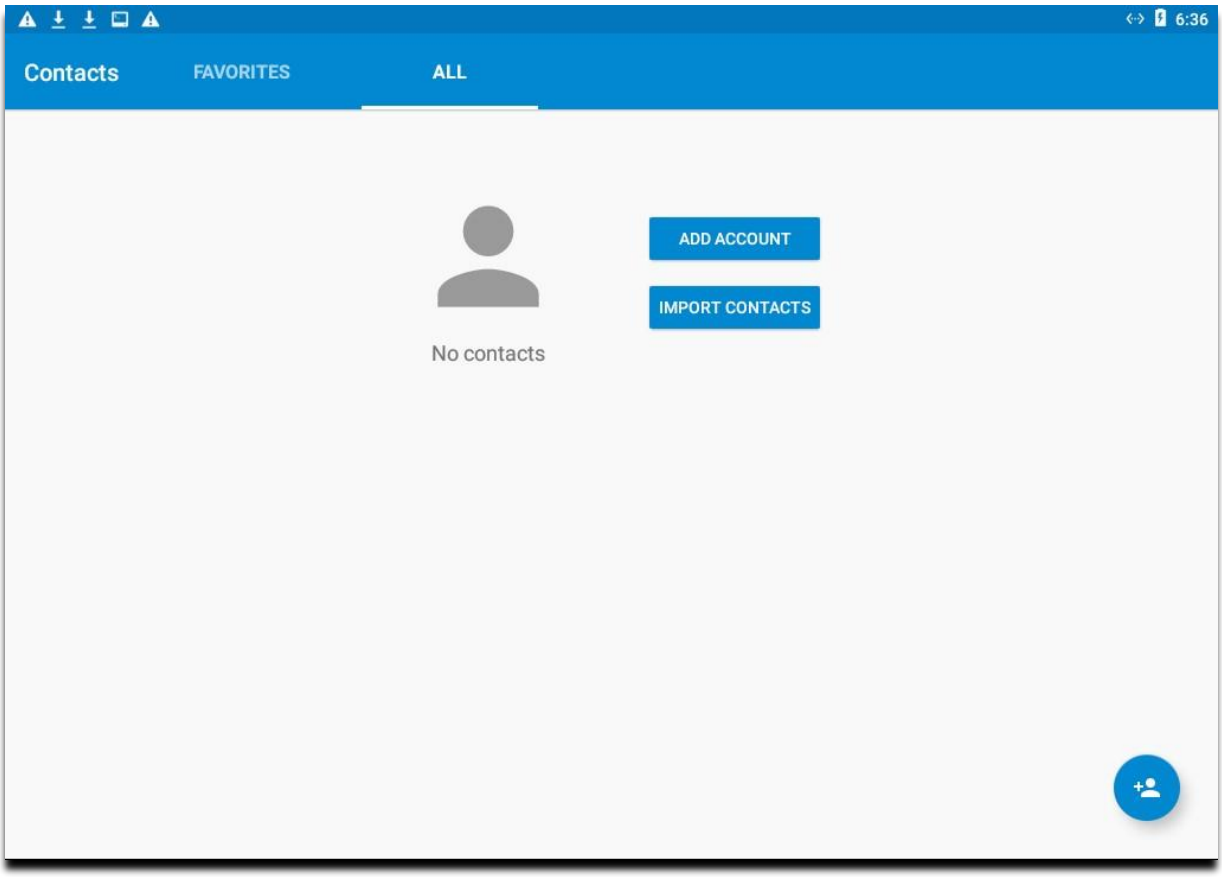
Εικόνα 18: Εκτέλεση της κακόβουλης εφαρμογής.

Αφού εκτελέσουμε την εφαρμογή, θα πρέπει να αλλάξουμε την ώρα χειροκίνητα για να εκτελεστεί ο κακόβουλος κώδικας, αφού περιμένει το action: "android.intent.action.TIME_SET".



Εικόνα 19: Αλλαγή της ώρας χειροκίνητα.

Όπως μπορείτε να διαπιστώσετε από την παρακάτω εικόνα, η εφαρμογή λειτούργησε κανονικά και διέγραψε όλες τις αποθηκευμένες επαφές στην συσκευή.



Εικόνα 20: Αποτέλεσμα επίθεσης.

Δραστηριότητα 6: Παρακολούθηση της τοποθεσίας του θύματος



Εικόνα 21: Διαμόρφωση DNS στο Android VM.

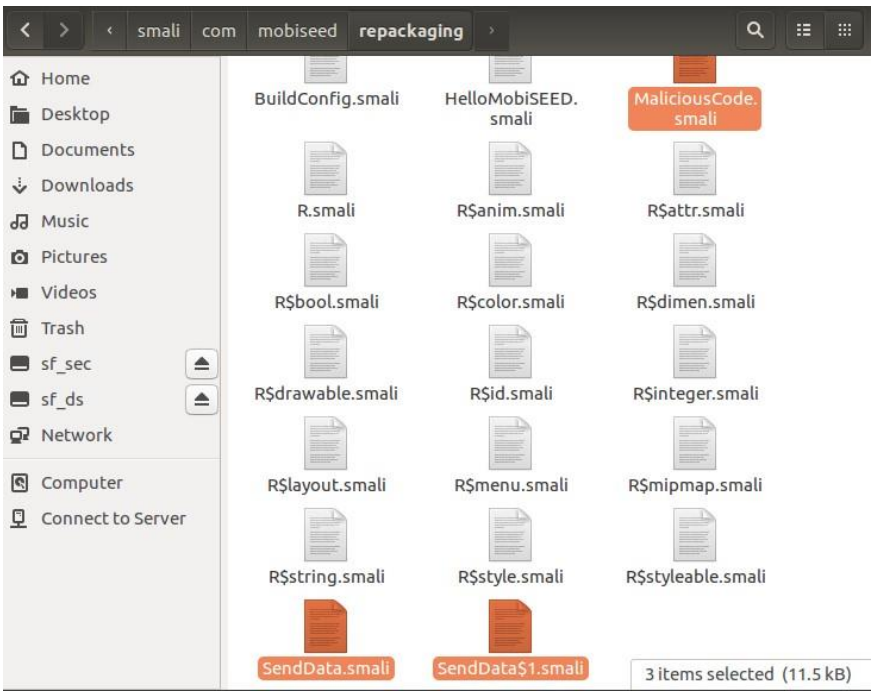
Για να λειτουργήσει το «www.repackagingattacklab.com» από την συσκευή του επιτιθέμενου, θα πρέπει να διαμορφώσουμε κατάλληλα τους DNS της android συσκευής όπως φαίνεται στην παραπάνω εικόνα.

Όπως και προηγουμένως, για να ενσωματώσουμε τον κακόβουλο κώδικα θα πρέπει να αποσυναρμολογήσουμε την εφαρμογή (ανοίξουμε). Στην συγκεκριμένη περίπτωση αυτό γίνεται με την εντολή $ apktool d RepackagingLab.apk.

```
[04/17/24]seed@VM:.../Scenario2$ apktool d RepackagingLab.apk
I: Using Apktool 2.2.2 on RepackagingLab.apk
I: Loading resource table...
I: Decoding AndroidManifest.xml with resources...
I: Loading resource table from file: /home/seed/.local/share/apkt
ool/framework/1.apk
I: Regular manifest package...
I: Decoding file-resources...
I: Decoding values */* XMLs...
I: Baksmaling classes.dex...
I: Copying assets and libs...
I: Copying unknown files...
I: Copying original files...
[04/17/24]seed@VM:.../Scenario2$
```

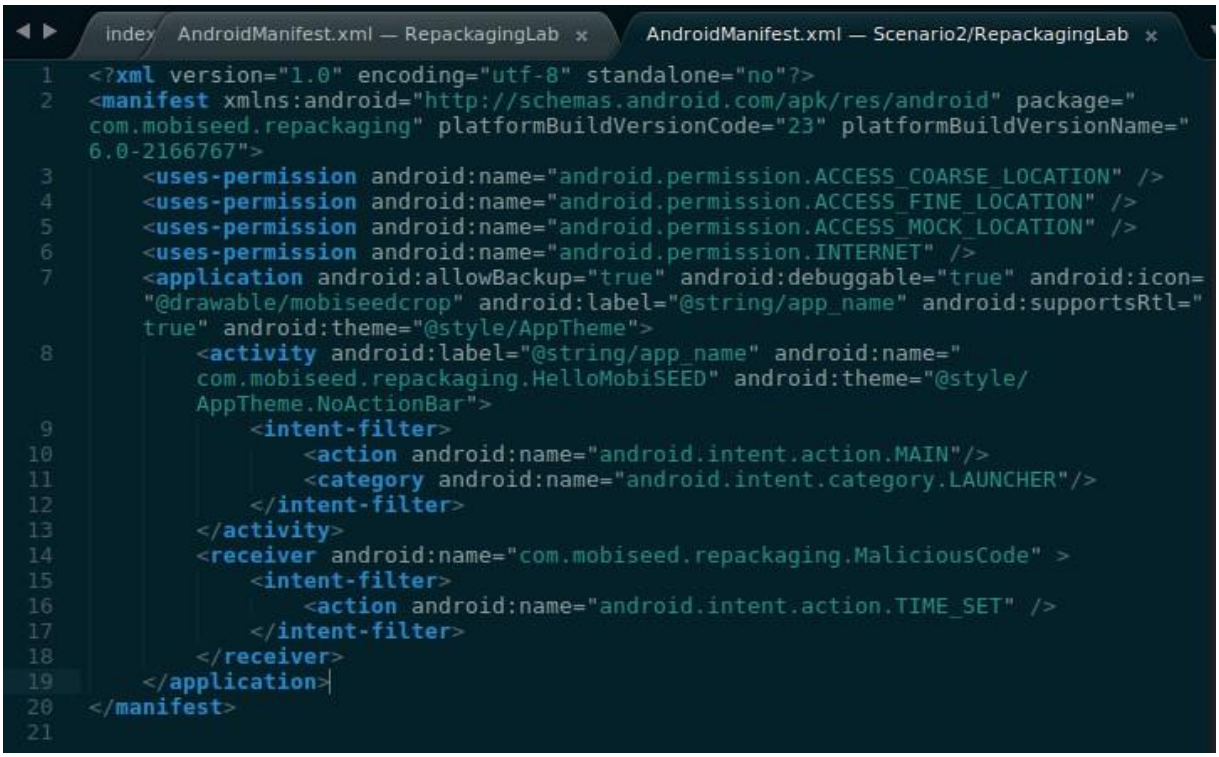
Εικόνα 22: Αποσυναρμολόγηση της εφαρμογής με το apktool.

Αφού, αποσυναρμολογήσαμε την εφαρμογή θα προσθέσουμε τα αρχεία με τον κακόβουλο κώδικα στον φάκελο smali/com/mobiseed/repackaging.



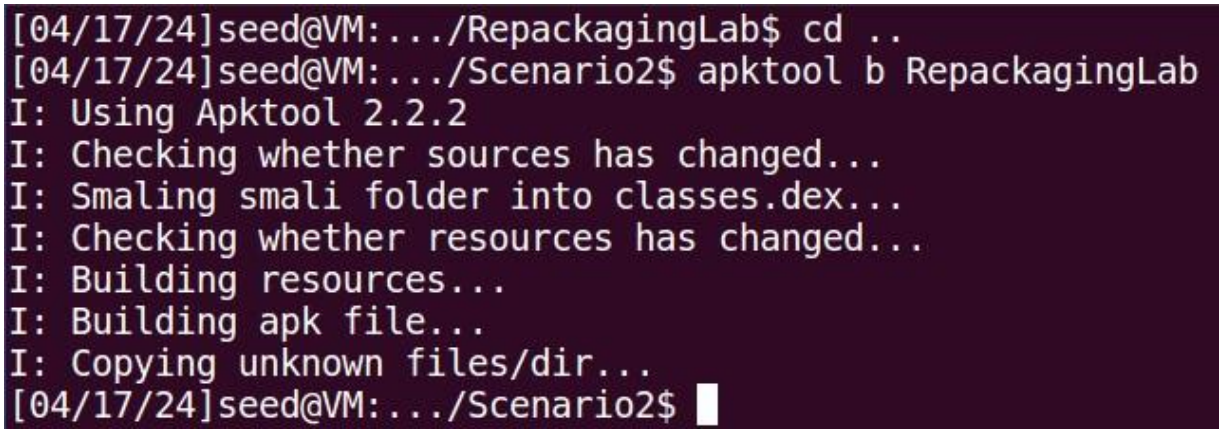
Εικόνα 23: Μετακίνηση των αρχείων με τον κακόβουλο κώδικα στον φάκελο smali/com/mobiseed/repackaging.

Στην συνέχεια, θα επεξεργαστούμε το AndroidManifest.xml ώστε να προσθέσουμε τις τέσσερις απαιτούμενες άδειες για την λειτουργία του κακόβουλου κώδικα. Τέλος, θα πρέπει να καταχωρήσουμε τον BroadcaseReceiver ώστε να λαμβάνει το συμβάν εκπομπής TIME SET.



Εικόνα 24: Επεξεργασία του AndroidManifest.xml.

Τέλος, επανασυναρμολογούμε την εφαρμογή. Στο συγκεκριμένο παράδειγμα με την εντολή $ apktool b RepackagingLab.apk.



Εικόνα 25: Επανασυναρμολόγηση της εφαρμογής με το apktool.

Υπογράφουμε την νέα εφαρμογή με το ίδιο κλειδί από τα προηγούμενα βήματα.

```
[04/25/24]seed@VM:.../3rd try 6$ jarsigner -keystore mykey.keysto
re RepackagingLab.apk thomas
Enter Passphrase for keystore:
jar signed.

Warning:
The signer certificate will expire within six months.
No -tsa or -tsacert is provided and this jar is not timestamped.
Without a timestamp, users may not be able to validate this jar a
fter the signer certificate's expiration date (2024-07-24) or aft
er any future revocation date.
```

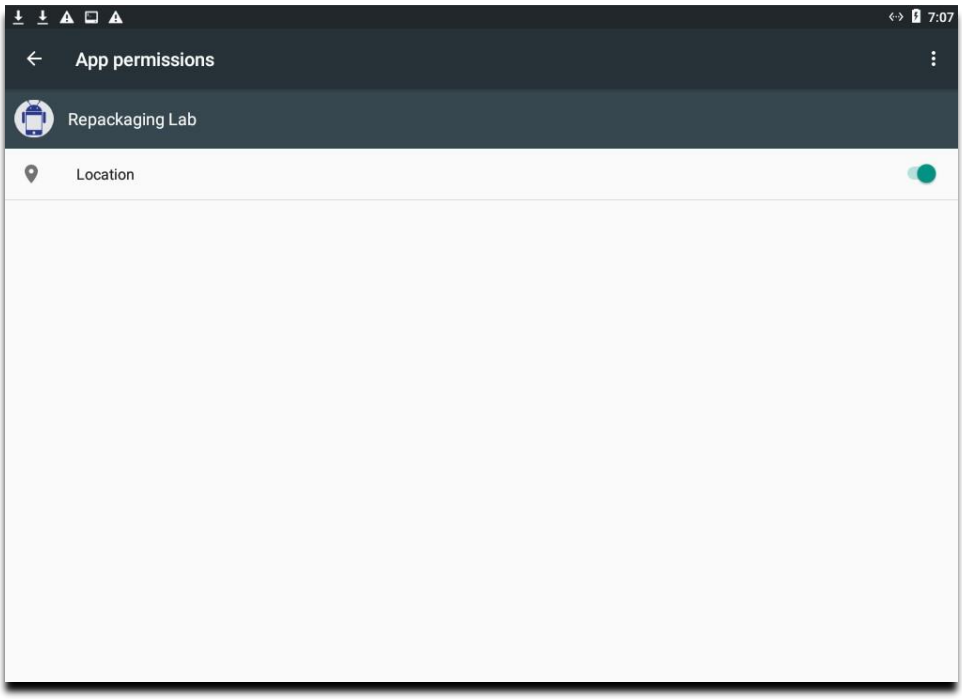
Εικόνα 26: Ψηφιακή υπογραφή του νέου αρχείου APK.

Εγκαθιστούμε την εφαρμογή με το adb στην συσκευή android του θύματος.

```
[04/17/24]seed@VM:.../dist$ adb install RepackagingLab.apk
1900 KB/s (1428317 bytes in 0.733s)
Success
[04/17/24]seed@VM:.../dist$
```

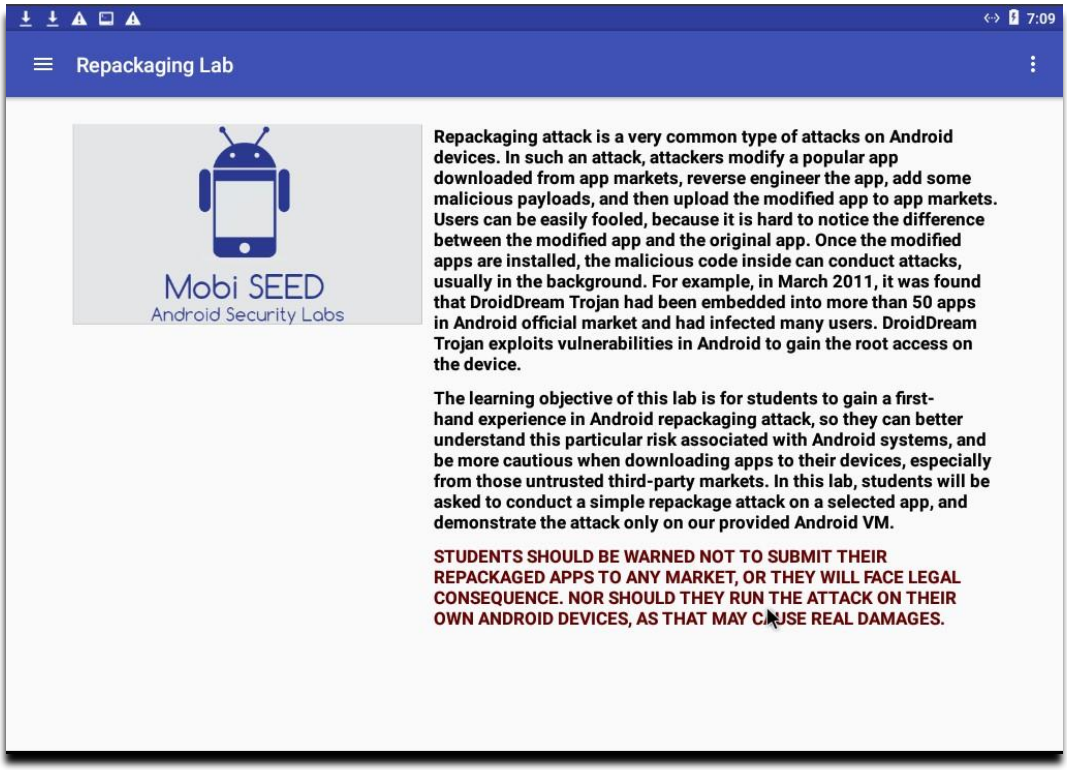
Εικόνα 27: Εγκατάσταση του apk στο SEEDAndroid VM χρησιμοποιώντας το adb.

Δίνουμε χειροκίνητα τα απιτούμενα δικαιώματα (location).



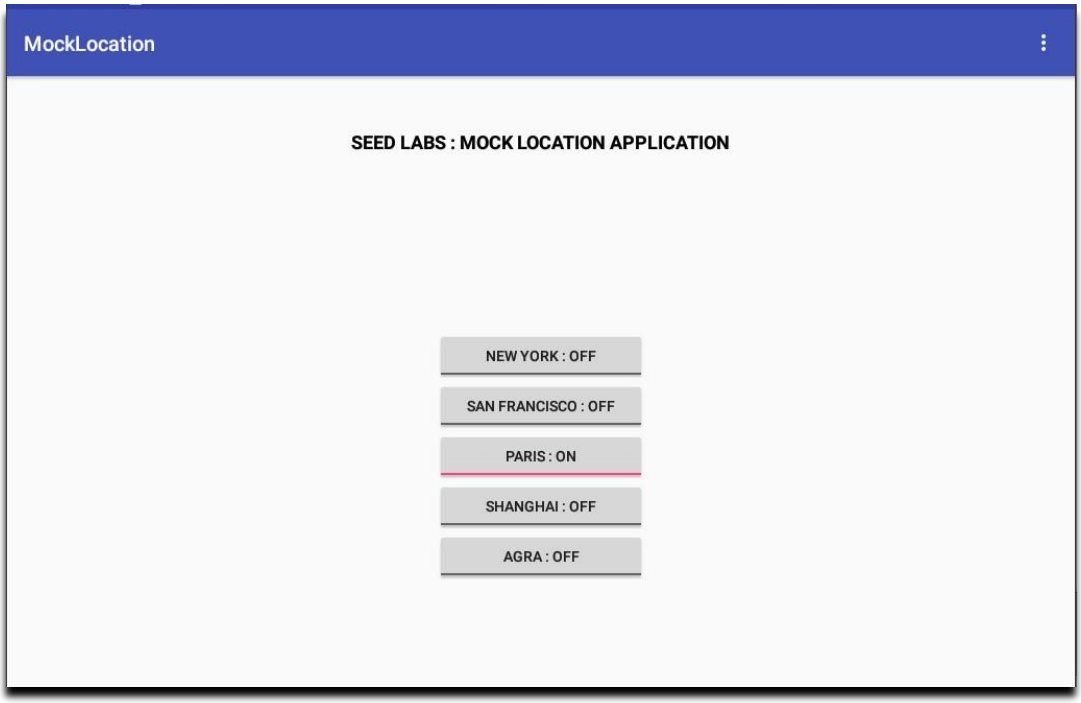
Εικόνα 28: Παραχώρηση των απαιτούμενων δικαιωμάτων.

Εκτελούμε την κακόβουλη εφαρμογή τουλάχιστον μία φορά.



Εικόνα 29: Εκτέλεση της κακόβουλης εφαρμογής.

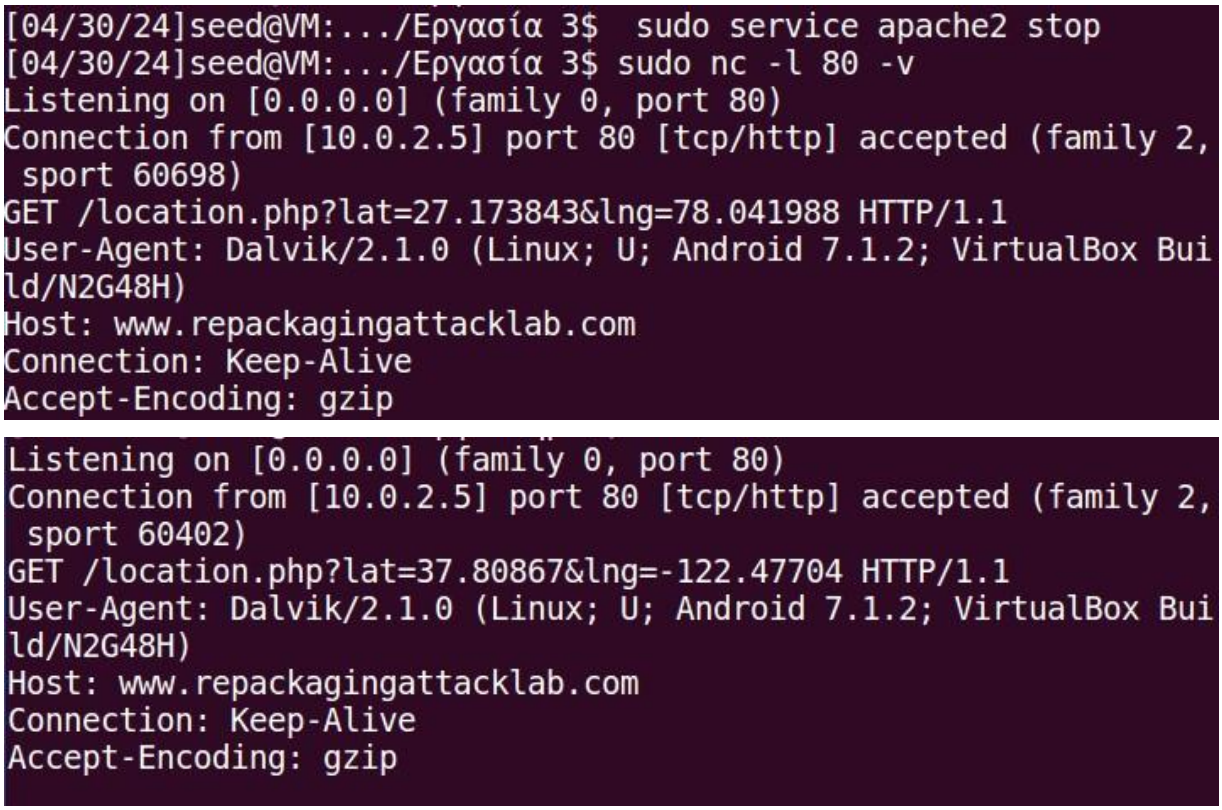
Επιλέγουμε μία τυχαία τοποθεσία από την εφαρμογή MockLocation.



Εικόνα 30: Αλλαγή τοποθεσίας με το MockLocation.

Αλλάζουμε την ώρα και πηγαίνουμε στην σελίδα «www.repackagingattacklab.com». Αν όλα τα παραπάνω βήματα έχουν εκτελεσθεί σωστά, θα πρέπει να βλέπουμε τον χάρτη με την τοποθεσία του θύματος.

Στην υλοποίηση αυτή, χρησιμοποιείται ο εναλλακτικός τρόπος. Με κάθε αλλαγή στην τοποθεσία και έπειτα αλλαγή στην ώρα, μπορούμε να εντοπίσουμε την νέα τοποθεσία.



Εικόνα 31: Αποτέλεσμα επίθεσης.

Παραπομπές:

Δρ. Γεωργούλας.